PS 1 — AI FOR ELECTORAL ROLL TRANSPARENCY

ElectraLens

Product Requirements & System Design

> *Public data, public methodology, public evidence, private identities.*

Founder	Aryan Yadav
Version	0.1 — draft for approval
Date	27 October 2026
Build window	24-hour hackathon, production-grade foundations
Budget	₹0 — existing VPS, Supabase free tier, testnets

Contents

1. Product Requirements Document
2. System Architecture
3. Threat Model and Privacy-by-Design Review
4. Implementation Roadmap and Decisions

Appendix — Sources and open checks

ElectraLens is an independent project. It is not affiliated with, endorsed by, or acting for the Election Commission of India. All demo data is synthetic.

PART 1

ElectraLens — Product Requirements Document

Version	0.1 (draft for founder approval)
Date	2026-10-27
Owner	Aryan Yadav
Track	PS 1 — AI for Electoral Roll Transparency
Build window	24-hour hackathon, built to production-grade standards
Status	Planning. No code yet.

Conventions used in all ElectraLens docs

- **[V]** verified against a source listed in README.md. **[A]** assumption that still needs checking. **[P]** proposal (a design choice, not a fact).
- Priority: **P0** = hackathon must-have, **P1** = hackathon should-have, **P2** = zero-cost pilot, **P3** = needs official cooperation, legal review or money.
- Requirement IDs (`FR-…`, `NFR-…`, `AC-…`) stay stable across all later stages.

---

1. Problem

Electoral rolls decide who can vote. They are large, published in formats that are hard to analyse, and revised often. Revisions can add or remove millions of names. Since mid-2025 India has run Special Intensive Revisions (SIR) in phases (Bihar first, a second phase from November 2025, a third announced for 2026), and draft-roll changes have been reported in crores of names [V]. Citizens can't easily tell what changed or why. Journalists and observers lack tools to audit at scale, and claims spread faster than anyone can check them.

ElectraLens makes roll changes **auditable, explainable and accessible**, without taking a political side.

2. What ElectraLens is, and what it is not

ElectraLens is	ElectraLens is not
An independent civic-tech tool with open methodology	An Election Commission system or anything endorsed by ECI
A way to compare roll versions and surface statistical anomalies for human review	A fraud detector. An anomaly is a reason to look closer, not proof of anything.
A publisher of aggregate, privacy-reviewed evidence with tamper-evident integrity proofs	A source of official voter status or a replacement for the ERO's claims-and-objections process
An information companion that links citizens to official ECI services	A voter-ID issuer or a substitute for identity checks at the polling station
A claim checker that says what the published data can and cannot establish	A judge of whether an election is legitimate

Core principle: public data, public methodology, public evidence, private identities.

3. Hard constraints

ID	Constraint	Consequence
C1	**Zero spend.** Existing Hostinger VPS, Supabase free tier, a subdomain of an existing domain, testnets only.	Every component must run on free tiers or self-hosted open source. Free-tier limits become design inputs (see Architecture §2).
C2	**Synthetic data only** for the hackathon (organiser rule).	A synthetic roll generator with injected, labelled anomalies is a P0 component, not a side tool.
C3	**Neutrality rules** (organiser rule): never declare fraud from an anomaly, never name individuals, parties or institutions, explain reasoning and uncertainty, apply the same standards everywhere.	Enforced in code (rule catalogue, banned-term filter, no party data), not only in the UI copy.
C4	No personal data on-chain. Public pages need no account.	Integrity layer stores hashes only; public portal is anonymous.
C5	The VPS already serves another production app behind host nginx.	ElectraLens binds to localhost ports, gets its own nginx server block and container resource limits, and must not disrupt the other app.
C6	Organiser deliverables: working prototype, live demo on test data, and a 45–90 second promo video.	Demo script and video are planned deliverables (Roadmap, stage S9).
C7	**24-hour build window**, with production-level quality expected.	Only P0 is committed. P1 is a stretch goal. "Production level" here means production-grade foundations: real deployment, RLS, staff MFA, secrets hygiene, hardened containers, backups, audit log, and automated tests for integrity and access control. It does not mean a certified service. Work that needs time to mature (independent security test, accessibility audit, repeated restore drills) moves to the pilot, and we say so openly.

4. Users

Persona	Needs	Account?
Citizen (often mobile, low bandwidth, Hindi-first)	"What changed in my area?" "How do I check my name?" "Where is my booth?" "Is this WhatsApp claim true?"	No. Optional for saved items and alerts.
Journalist / fact-checker	Citable evidence, methodology, downloadable aggregates, a way to verify that a report wasn't altered	No
Observer / researcher	Version-to-version comparisons at scale, reproducible results, raw aggregate exports	No
ElectraLens staff: data steward, analyst, reviewer, publisher, security auditor, system admin	Controlled workflows with separation of duties	Yes, invite-only, MFA required
Election official (future)	Read-only view of findings in their jurisdiction to investigate or correct	P3, needs a formal arrangement
Hackathon judge	See the full pipeline work live in a few minutes	No

5. User stories

Citizen

- US-C1 As a citizen I can see, without signing up, how many names were added, deleted or corrected in my constituency between two roll versions.
- US-C2 I can read a plain-language explanation of any flagged pattern, including innocent explanations, in Hindi, English or a third language.

- US-C3 I can scan a QR code on a poster and see my polling station's details, where they came from and when they were last verified.
- US-C4 I am sent to the official ECI service to check my own registration or apply for inclusion, correction or deletion. ElectraLens never pretends to be that service.
- US-C5 I can paste or type a claim ("50% of voters were deleted in X") and get a verdict: consistent with the published data, contradicted by it, or not something this data can establish.
- US-C6 I can optionally create an account to save reports and booths and get alerts when a dataset I follow changes.
- US-C7 I can ask simple questions by voice where my browser supports it.

Journalist / observer

- US-J1 I can download the aggregate tables and the report behind any finding.
- US-J2 I can verify, in my own browser, that a downloaded report matches the hash anchored on a public blockchain at publication time.
- US-J3 I can read the exact methodology version, thresholds and code version used for a run.
- US-J4 I can see the publication history, including corrections and retractions, which are never silently deleted.

Staff

- US-S1 (Data steward) I can upload a permitted dataset, record its provenance, and see a validation report. Bad files are quarantined.
- US-S2 (Analyst) I can run an audit comparing two approved versions and inspect findings with row-level evidence inside the restricted workspace.
- US-S3 (Reviewer) I can accept, downgrade or reject each finding with a reason, and I cannot review a run I created.
- US-S4 (Publisher) I can publish a reviewed report only after a second, different person has approved it. Publishing triggers integrity anchoring.
- US-S5 (Publisher) I can issue a correction or retraction that creates a new version linked to the old one.
- US-S6 (Security auditor) I can read the audit log and security events but cannot change data.
- US-S7 (System admin) I can invite staff, assign scoped roles and revoke access immediately. I cannot publish on my own.

Judge

- US-D1 I can watch: generate a synthetic roll, run an audit, open a finding, verify its integrity proof, tamper with one record, and watch verification fail.

6. Functional requirements

M1. Data ingestion

ID	Requirement	Pri
FR-ING-1	Accept only CSV or Parquet files that match a declared, versioned schema (`electoral_roll_v1` , `polling_stations_v1`). Reject anything else. Size limit is configurable (default 50 MB).	P0
FR-ING-2	Record provenance: source, permission basis (synthetic / public / authorised), retrieval URL and time, uploader, original file SHA-256.	P0
FR-ING-3	Validate types, ranges, required fields, enum codes and referential integrity (every part number exists in `jurisdictions`).	P0
FR-ING-4	Quarantine invalid files with a machine-readable ingestion report. Never auto-delete them.	P0
FR-ING-5	Classify columns as direct identifiers, quasi-identifiers or non-identifying. Direct identifiers never leave the restricted tier.	P0

ID	Requirement	Pri
FR-ING-6	Produce the canonical form and its Merkle root (see Architecture §8) so the same data always gives the same commitment.	P0
FR-ING-7	Keep the original file and checksum read-only in private storage.	P0
FR-ING-8	No URL-based import in the MVP (it opens SSRF risk). If added later, only allow-listed hosts.	P2
FR-ING-9	Stewards approve a validated version before analysts can use it.	P1

M2. Audit engine

ID	Requirement	Pri
FR-AUD-1	Synthetic roll generator: realistic structure (state → district → assembly constituency → part), Indian-style names in Devanagari and Latin, ages, genders, house numbers, relative names, multiple versions over time, deletion reason codes. Injects labelled anomalies with a seed.	P0
FR-AUD-2	Version diff: additions, deletions, corrections, per part and constituency, with deletion reasons where present.	P0
FR-AUD-3	Deterministic rules (catalogue in Architecture §9): exact and likely duplicates, impossible ages, age inconsistent across versions, abnormal deletion or addition rate, high-occupancy addresses, gender-ratio shift, missing or invalid fields.	P0
FR-AUD-4	Rate checks use a stated statistical test against a stated baseline, with false-discovery-rate control across parts and a minimum effect size.	P0
FR-AUD-5	Every finding carries: ID, dataset versions, rule and version, evidence, baseline, threshold, plain-language explanation, alternative explanations, signal strength with uncertainty, limitations, review status.	P0
FR-AUD-6	Runs are reproducible: same inputs, code version and parameters give byte-identical outputs. The run records all three.	P0
FR-AUD-7	Detection quality is measured against the injected anomalies (precision and recall per rule) and shown on the methodology page.	P1
FR-AUD-8	ML methods (for example Isolation Forest) are added only if they beat the rules on the measured benchmark.	P2
FR-AUD-9	Every run covers every part in the dataset. Nobody picks which areas get analysed, so the tool can't be used to cherry-pick.	P0

M3. Explanations

ID	Requirement	Pri
FR-EXP-1	Explanations are generated from the finding's evidence JSON using reviewed templates in English, Hindi and one more language. No network or LLM needed.	P0
FR-EXP-2	Each finding type has a curated list of innocent explanations (migration, death-record catch-up, part reorganisation, duplicate clean-up drive, house-to-house revision, data-entry batching).	P0
FR-EXP-3	Optional LLM rephrasing or Q&A only sees public evidence JSON. Its output is checked: every number and place must appear in the evidence, banned terms are blocked, and it falls back to the template on any failure. Off by default.	P1
FR-EXP-4	Generated text never uses accusatory terms ("fraud", "rigged", "stolen", "fake voters") or names parties, candidates or people.	P0

M4. Public transparency portal

ID	Requirement	Pri
FR-PUB-1	Home: published datasets, latest revision summary, what ElectraLens is and isn't. No login.	P0
FR-PUB-2	Version comparison page: additions, deletions and corrections by area, with charts and a table.	P0
FR-PUB-3	Findings list and finding detail page (evidence, baseline, explanation, alternatives, uncertainty, review status).	P0
FR-PUB-4	Methodology page: rules, thresholds, statistical tests, versions, known limitations, measured detection quality.	P0

ID	Requirement	Pri
FR-PUB-5	Verification page: recompute a report's hash in the browser and compare it with the on-chain record read directly from a public RPC, so the check doesn't depend on our server.	P0
FR-PUB-6	Provenance and publication history, including corrections and retractions.	P0
FR-PUB-7	Every piece of content carries a label: *Source data*, *Analytical finding*, *User-submitted claim*, *Unverified / inconclusive*, *Confirmed correction*.	P0
FR-PUB-8	Aggregate downloads (CSV and JSON), each with its hash.	P1
FR-PUB-9	Small-cell suppression on every public breakdown (Threat model §5.3).	P0
FR-PUB-10	Links to official ECI services, clearly marked as external and official.	P0

M5. Claim checker

ID	Requirement	Pri
FR-CLM-1	A structured claim form (area, metric, period, value, direction).	P0
FR-CLM-2	Optional free-text input, parsed into the structured form by an LLM. The user confirms the parsed form before evaluation.	P1
FR-CLM-3	The verdict is computed by code against published aggregates, never by an LLM. Verdicts: **Consistent with published data**, **Contradicted by published data**, **Disputed** (published sources disagree), **Cannot be established from available data**.	P0
FR-CLM-4	Claims about intent, fraud or wrongdoing always get "Cannot be established from this data", with an explanation of why.	P0
FR-CLM-5	Submissions are protected by Turnstile and rate limits. Claims are only published after moderation.	P1

M6. Citizen assistant

ID	Requirement	Pri
FR-AST-1	Guided flows: check my registration (link-out), apply or correct (link-out to the official forms), find my booth, understand a change, check a claim.	P0
FR-AST-2	English, Hindi and one more language for the whole UI and all templates. Translations reviewed by a fluent speaker.	P0
FR-AST-3	Voice input and output through the browser's speech APIs, where available, with a privacy notice.	P1
FR-AST-4	Free-text Q&A grounded only in published content and the official-links catalogue.	P2

M7. Integrity layer

ID	Requirement	Pri
FR-INT-1	Deterministic canonicalisation (RFC 8785 JSON, NFC, fixed ordering) and SHA-256 Merkle roots (RFC 6962 construction).	P0
FR-INT-2	One publication manifest per publication, linking dataset roots, run, parameters, report hash, aggregates hash and the previous manifest.	P0
FR-INT-3	Append-only Solidity registry on an Ethereum testnet: anchor, retract (a new event, never a delete), no overwrite, role-based publishing.	P0
FR-INT-4	OpenTimestamps proof of the same manifest hash (free, anchored in Bitcoin).	P1
FR-INT-5	Verification returns match or mismatch, plus transaction, block, time and the manifest diff.	P0
FR-INT-6	A tamper demo mode, on synthetic data only.	P0
FR-INT-7	Identical canonicalisation in Python and TypeScript, with shared test vectors.	P0

M8. Polling booths and QR codes

ID	Requirement	Pri
FR-QR-1	Booth page `/b/{public_code}` : station name, address, parts served, accessibility notes, source, last verified time, official links.	P0
FR-QR-2	The QR code holds only the booth page URL with a random public code. No personal data, credentials or tokens.	P0
FR-QR-3	Printable QR posters per booth or ward, with a "not an official document" notice.	P1
FR-QR-4	Booth data goes through ingestion and approval like any dataset. Synthetic booths are watermarked "DEMO — fictional".	P0
FR-QR-5	No per-voter QR codes.	P0 (exclusion)

M9. Accounts

ID	Requirement	Pri
FR-ACC-1	Citizen sign-in with Supabase Auth: Google OAuth and email magic link. Never EPIC number as a login or password.	P1
FR-ACC-2	Citizen data is limited to display name (optional), language and notification preferences, saved items and subscriptions.	P1
FR-ACC-3	Self-service account deletion that removes all citizen data.	P1
FR-ACC-4	Staff accounts are invite-only. Roles are granted only by a system admin, through the API, never via signup metadata.	P0
FR-ACC-5	Staff must use TOTP MFA. Staff data access is enforced by RLS that requires `aal2` .	P0
FR-ACC-6	Roles can be scoped to a jurisdiction. Revoking a role takes effect on the next request.	P1

M10. Operations console and governance

ID	Requirement	Pri
FR-GOV-1	Separate workspaces for steward, analyst, reviewer, publisher, auditor and admin.	P0 (steward, analyst, reviewer, publisher), P1 (rest)
FR-GOV-2	Two-person rule, enforced in the database: a publication needs a reviewer approval and a publisher approval from two different people, neither of whom created the run.	P0
FR-GOV-3	Append-only audit log of security-relevant actions (actor, time, action, target, reason). UPDATE and DELETE are revoked at the database level.	P0
FR-GOV-4	Corrections and retractions create new linked versions. Nothing is silently deleted.	P0
FR-GOV-5	Job dashboard (ingest, analyse, publish, anchor) with status and retry.	P1
FR-GOV-6	Incident records and security event views.	P2

7. Non-functional requirements

ID	Area	Requirement
NFR-1	Privacy	No direct identifiers in any public table, API response, file, log line, LLM prompt or on-chain value. An automated PII scan of public API responses runs in CI.
NFR-2	Security	Least privilege at every layer. Secrets only on the server. RLS on every table. Staff MFA. Layered defences, with no claim of "unhackable".
NFR-3	Neutrality	Same rules and thresholds for every area. No party, candidate or vote-share data is ingested. Methodology is versioned and public before results.

ID	Area	Requirement
NFR-4	Reproducibility	Deterministic engine, pinned dependencies, recorded code version and container digest, golden-output tests.
NFR-5	Performance	Public pages are server-rendered and cacheable. Target under 2.5 s Largest Contentful Paint on a mid-range phone over 4G for cached pages [P]. Audit run on a 200k-row synthetic roll in under 2 minutes on the VPS [A, depends on VPS size].
NFR-6	Availability	Single-VPS best effort, with no SLA claims. Public pages degrade to cached content if Supabase is unreachable.
NFR-7	Accessibility	Target WCAG 2.2 AA: keyboard navigation, contrast, screen-reader labels, charts with table alternatives.
NFR-8	Localisation	All UI strings and templates externalised. No machine-only translation of civic content without human review.
NFR-9	Low bandwidth	Public pages usable on 2G/3G. Minimal client JavaScript on public routes.
NFR-10	Cost	₹0 per month in recurring spend (C1).
NFR-11	Observability	Structured logs without PII, health endpoints, uptime checks, job failure alerts.
NFR-12	Maintainability	Monorepo, typed contracts shared between services, tests for security and integrity properties.
NFR-13	Legal posture	Not an official system. Visible disclaimer. Real voter data needs legal review first. DPDP Act obligations apply to citizen accounts (Threat model §5.5).

8. Scope

In scope for the hackathon MVP (committed: every P0 requirement; stretch: P1 requirements, in the order of the Roadmap cut list) Synthetic data pipeline, audit engine, template explanations in three languages, public dashboard, comparison, finding detail, methodology, browser-side verification with tamper demo, testnet registry, booth pages with QR codes on synthetic booths, structured claim checker, guided assistant, minimal staff console with the two-person publish rule, deployment on the subdomain.

Explicit exclusions

- Real voter data of any kind during the hackathon.
- Scraping, automating or proxying official ECI portals. They are bot-protected and intended for interactive use. ElectraLens links out instead.
- Per-voter lookups, per-voter QR codes, EPIC-based login.
- Party, candidate, vote-share or turnout data.
- Any automated "fraud" or legitimacy verdict.
- Mainnet anchoring, paid APIs, paid tiers (C1).
- Anything that presents ElectraLens as official.

9. Acceptance criteria (hackathon MVP)

ID	Criterion
AC-1	From a clean state, the live demo goes from "generate synthetic roll" to "tamper detected" in under 5 minutes with no manual database edits.
AC-2	Running the same audit twice on the same inputs gives identical output hashes (automated test).
AC-3	The CI PII scan finds no names, relative names, house numbers or synthetic EPIC-format strings in any public API response or published file.
AC-4	RLS tests prove that anonymous users read only published rows, citizens read only their own rows, and staff without `aal2` read nothing restricted.

ID	Criterion
AC-5	A test proves a publication can't reach `approved` with one approver, with the run's creator as approver, or with two approvals from the same person.
AC-6	Changing one character in one record changes the dataset root, and the verification page shows a mismatch together with the original anchor transaction.
AC-7	Python and TypeScript canonicalisers produce identical hashes for every shared test vector, including Devanagari, empty fields and reordered rows.
AC-8	Precision and recall per rule on the injected-anomaly benchmark are computed and displayed. No target is claimed until measured.
AC-9	Each finding page shows evidence, baseline, threshold, explanation, at least two alternative explanations, uncertainty and review status in all three languages.
AC-10	The banned-term test passes on every template and on LLM output when the LLM is enabled.
AC-11	Every QR code decodes to `https://<subdomain>/b/<code>` with nothing else in it.
AC-12	The claim checker returns each of the four verdict types on prepared test claims, and intent or fraud claims return "Cannot be established".

10. Success metrics

No traction is claimed before it exists. These are the measures we will report honestly.

Hackathon: AC-1 to AC-12 pass. The demo runs live, not from a recording. **Pilot (after the hackathon):** number of published reports; number of independent verifications (browser verifier runs, counted without personal data); median time from dataset approval to published report; share of findings reviewed within 7 days; claims checked per month; accessibility audit score; PII incidents (target: zero, reported publicly if any).

11. Open questions

These are tracked as decisions D1–D10 in 04-ROADMAP.md.

PART 2

ElectraLens — System Architecture

Version 0.1 · 2026-10-27 · Draft for approval. Conventions ([V]/[A]/[P], IDs) as in 01-PRD.md.

1. Where ElectraLens fits in the electoral process

Different authorities control different stages of an Indian election. ElectraLens works on only two of them, the roll and voter information, and links out for everything official.

Stage	Responsible	Legal basis	ElectraLens role
Roll preparation and revision (annual summary revision, intensive revision, SIR, continuous updating)	Chief Electoral Officer (state), District Election Officer, Electoral Registration Officer (ERO) per assembly constituency, Assistant EROs, Booth Level Officers (BLO) per part	Representation of the People Act 1950; Registration of Electors Rules 1960. Four qualifying dates (1 Jan, 1 Apr, 1 Jul, 1 Oct) since the 2021 amendment, effective 1 Aug 2022 [V]	**Core.** Version comparison, anomaly detection, explanations.
Claims and objections: Form 6 (inclusion), 7 (objection/deletion), 8 (correction/shifting), plus 6A and 6B	ERO decides. Appeals go to the District Magistrate, then the CEO [V]	RP Act 1950, RER 1960	**Explain and link out.** Guide citizens to the official forms. Never file on anyone's behalf.
Announcement, Model Code of Conduct	ECI	Article 324; RP Act 1951	None
Nominations, scrutiny, withdrawal	Returning Officer	RP Act 1951	None
Campaign	Candidates and parties	MCC	None (neutrality)
Polling-station setup, voter information	DEO and RO; BLOs distribute voter information slips. Cap of 1,200 electors per station reinstated in 2025 [V, secondary sources]	ECI instructions	**Companion.** Booth pages from verified public data, QR posters.
Identity checks on polling day	Presiding and polling officers	Conduct of Election Rules 1961	None. ElectraLens is never an ID.
Counting and results	RO and counting staff	RP Act 1951, CE Rules 1961	None. No vote data is ingested.

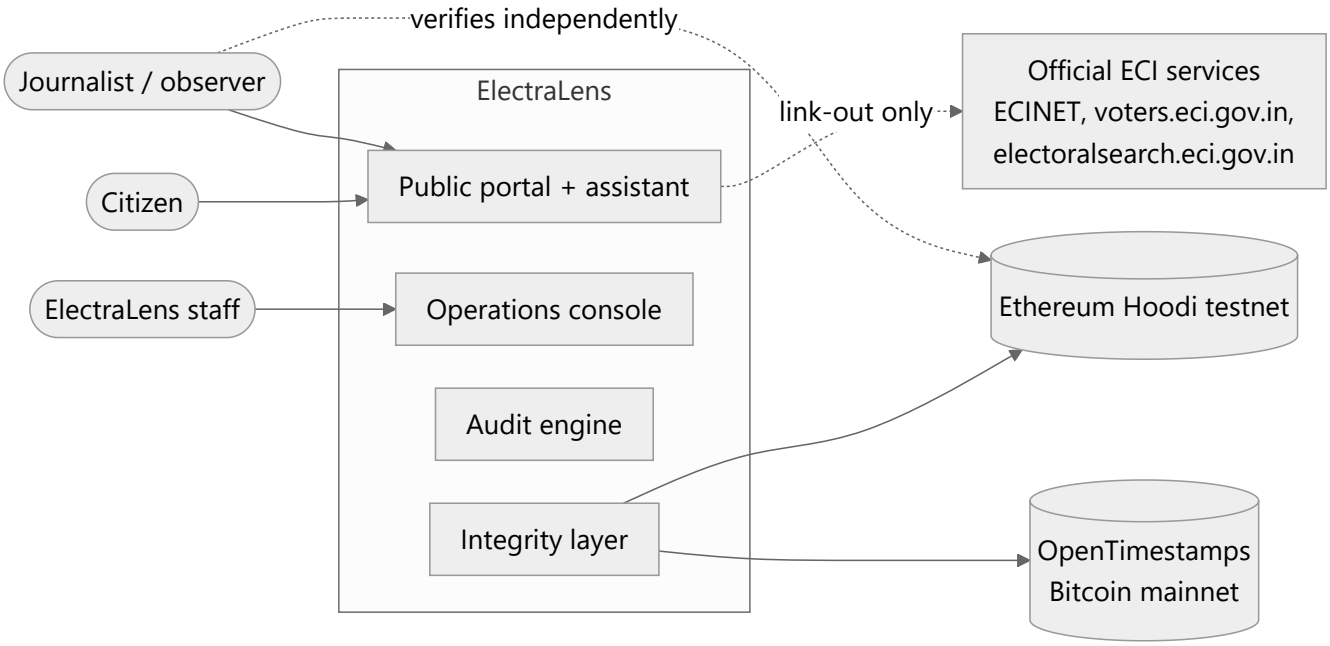
Official services we link to, but don't integrate with. ECINET, ECI's single app launched January 2026, which merges 40+ earlier apps including Voter Helpline [V, news]. Also voters.eci.gov.in and electoralsearch.eci.gov.in. I found **no documented public API** for electoral search or booth lookup. These portals are meant for interactive use, and automating them would bypass their bot protection, so we don't. Any integration needs ECI authorisation (P3).

2. Stack evaluation (zero-cost)

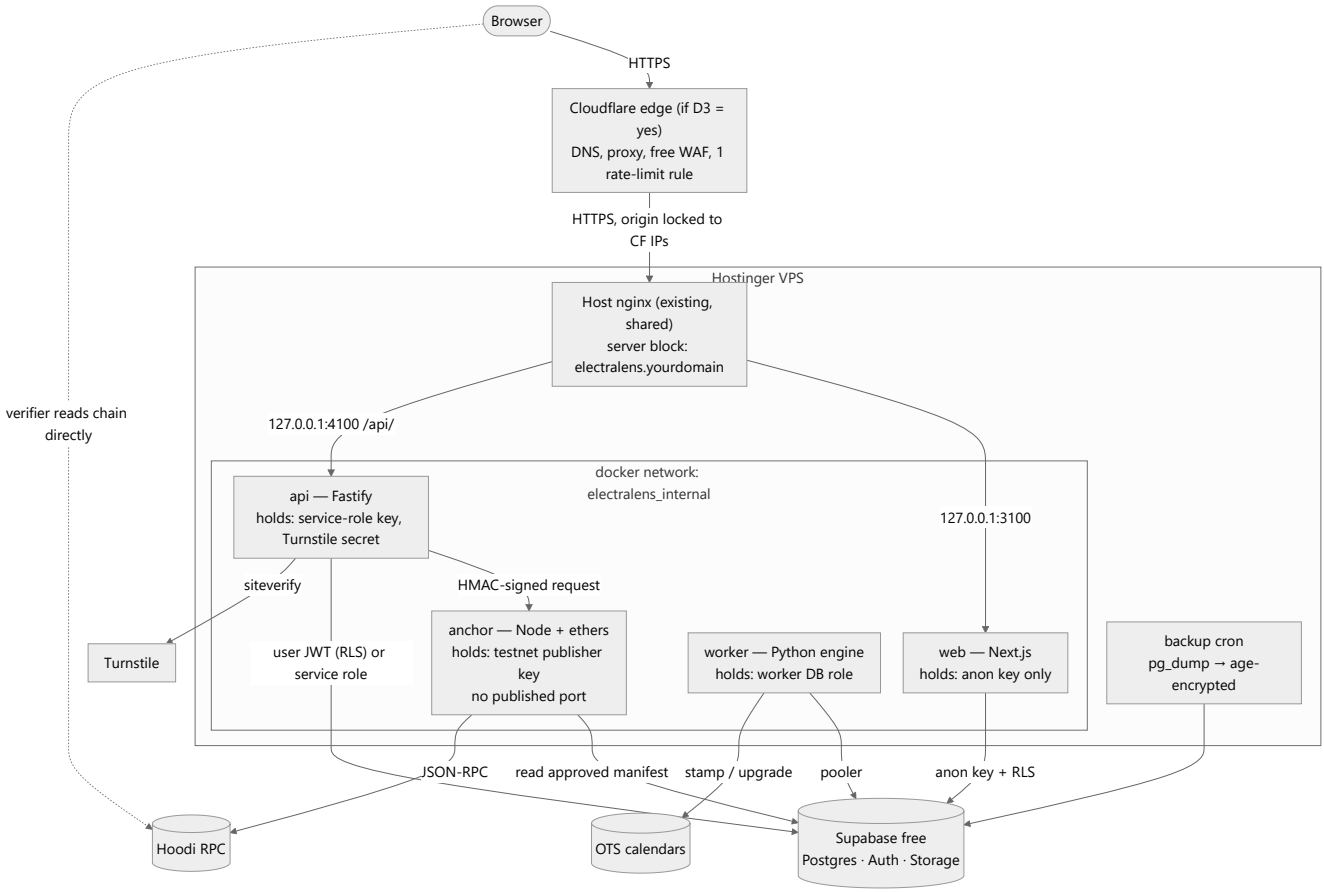
Requested	Verdict	Why it's needed / what changes
Hostinger VPS	**Keep**	Already paid for. Runs all ElectraLens containers. It also serves your other app behind host nginx, so ElectraLens binds to localhost ports with its own nginx server block and memory limits. **VPS RAM and CPU are unknown [A]**: we need about 1.5 GB free.

Requested	Verdict	Why it's needed / what changes
Supabase free tier	**Keep, with mitigations**	Postgres, Auth and Storage without running them ourselves. Free-tier facts [V] and how we handle them: **no automatic backups** → our own nightly encrypted `pg_dump`. **Paused after 1 week of inactivity** → the worker polls every few seconds, plus a daily health query [A: that this counts as activity]. **500 MB database** → row-level data stays out of Postgres (§6). **1 GB storage** → enough for synthetic datasets. **2 free projects**, one taken by your other app → production is the second, and development runs on the local Supabase CLI in Docker. **Default email: 2 per hour, team members only** → custom SMTP on a free sender (Gmail app password or Brevo free). Custom Access Token hook and TOTP MFA are available on Free [V].
Supabase Auth	**Keep**	Citizen OAuth and magic links, staff TOTP MFA, `aal2` checks inside RLS.
Cloudflare free	**Keep, conditional**	The free plan only supports **full setup**, meaning your whole domain's nameservers move to Cloudflare. Proxying just a subdomain needs Business [V]. Free gives one rate-limiting rule (10 s window) and the free managed WAF ruleset [V]. **Turnstile works without the proxy** (free, unlimited challenges, 20 widgets) [V]. See decision D3.
Next.js + TypeScript	**Keep**	Server rendering for fast, crawlable, low-JS public pages. One app with three areas: public, citizen, ops console.
Node.js backend	**Keep, as a separate Fastify service**	Next.js route handlers would put privileged keys inside the internet-facing web container. A separate API holds the service-role key, enforces authorisation, rate limits and audit logging, and gives one clear security boundary. Cost: one ~150 MB container.
Python analytics	**Keep**	Polars, SciPy and RapidFuzz make the rule engine and statistics straightforward. Runs as a queue worker, never inside web requests.
Solidity + EVM	**Keep, on the Hoodi testnet**	Append-only, publicly readable registry of publication hashes. ethereum.org recommends Sepolia for app development and Hoodi for validator testing [V], but Sepolia faucets couldn't fund fresh wallets in your earlier project and you already have Hoodi test ETH, so Hoodi is the practical choice. The network is a config value, so switching is cheap.
(added) OpenTimestamps	**Add**	Free, no API key, anchors hashes in **Bitcoin mainnet** through public calendars [V]. Testnets can be retired (Holesky was shut down in 2025 [V]), so this gives a durable second proof at zero cost.
SHA-256	**Keep, plus canonicalisation**	RFC 8785 JSON canonicalisation and an RFC 6962-style Merkle tree (§8). Hashing raw CSV bytes is not enough.
Docker Compose	**Keep**	Separate compose project, its own network, resource limits.
(added) Postgres job queue	**Add instead of Redis**	`FOR UPDATE SKIP LOCKED` on a `jobs` table. No extra service, and jobs change state in the same transaction as their data. We poll because LISTEN/NOTIFY doesn't work through Supabase's transaction pooler.
(LLM)	**Optional, off by default**	No paid API (C1). Explanations come from reviewed templates, so they're deterministic, free and can't hallucinate. Optional adapters: Gemini API free tier (its 2026 limits changed several times, and free-tier prompts may be used to improve Google products [V, secondary]) or a small local model via Ollama if the VPS has spare RAM [A]. Only **public** evidence is ever sent.

3. Context



4. Deployment



5. Components

Component	Responsibility	Credentials it holds	Never does
web (Next.js)	Public portal, assistant, booth pages, browser-side verifier, citizen pages, ops console UI. Server-renders public pages with incremental revalidation.	Supabase URL and anon key	Hold the service-role key; write data directly
api (Fastify)	All writes and staff workflows. Turnstile validation, rate limits, audit logging, signed upload URLs, QR generation, claim evaluation, job enqueueing.	Service-role key (used only for system operations), Turnstile secret, HMAC key for anchor	Hold the chain key; run long analyses
worker (Python)	Ingestion validation, canonicalisation, Merkle roots, diffs, rules, statistics, template explanations, report generation, OpenTimestamps stamping and upgrading.	Dedicated Postgres role with narrow grants (P1; MVP uses the service role)	Serve HTTP; publish anything
anchor (Node, ethers v6)	Re-reads an approved publication, **recomputes the manifest hash itself**, checks the two approvals, sends `anchor()`, records the receipt. One transaction at a time, with nonce management.	Testnet publisher private key (a dedicated hot wallet, not your personal wallet)	Accept a hash from the caller; reachable from outside the Docker network
Supabase Postgres	System of record. RLS on every table. Workflow state machine in `security definer` functions.	—	—
Supabase Auth	Citizen OAuth and magic links. Staff email, password and TOTP MFA. Custom access token hook adds UI role hints.	—	Decide authorisation. Roles are always re-checked in tables.
Supabase Storage	`datasets-restricted` (private), `quarantine` (private), `public-artifacts` (public read, written only after publication).	—	—
Host nginx	TLS, security headers, routing, request size limits, `limit_req` fallback rate limits, origin lock.	TLS certificate	Serve ElectraLens files directly
Cloudflare	DNS, proxy, caching, free WAF, one rate-limiting rule. **Turnstile** for claim submissions and citizen sign-in.	—	—
ElectraLensRegistry (Solidity)	Append-only publication registry with role-based publishing.	Admin role = your MetaMask testnet wallet (offline). Publisher role = the anchor hot wallet.	Store anything but hashes and IDs; get upgraded
Browser verifier	Downloads the manifest and report, recomputes hashes with WebCrypto, reads the chain from a public RPC, shows match or mismatch.	—	Trust our API for the verdict

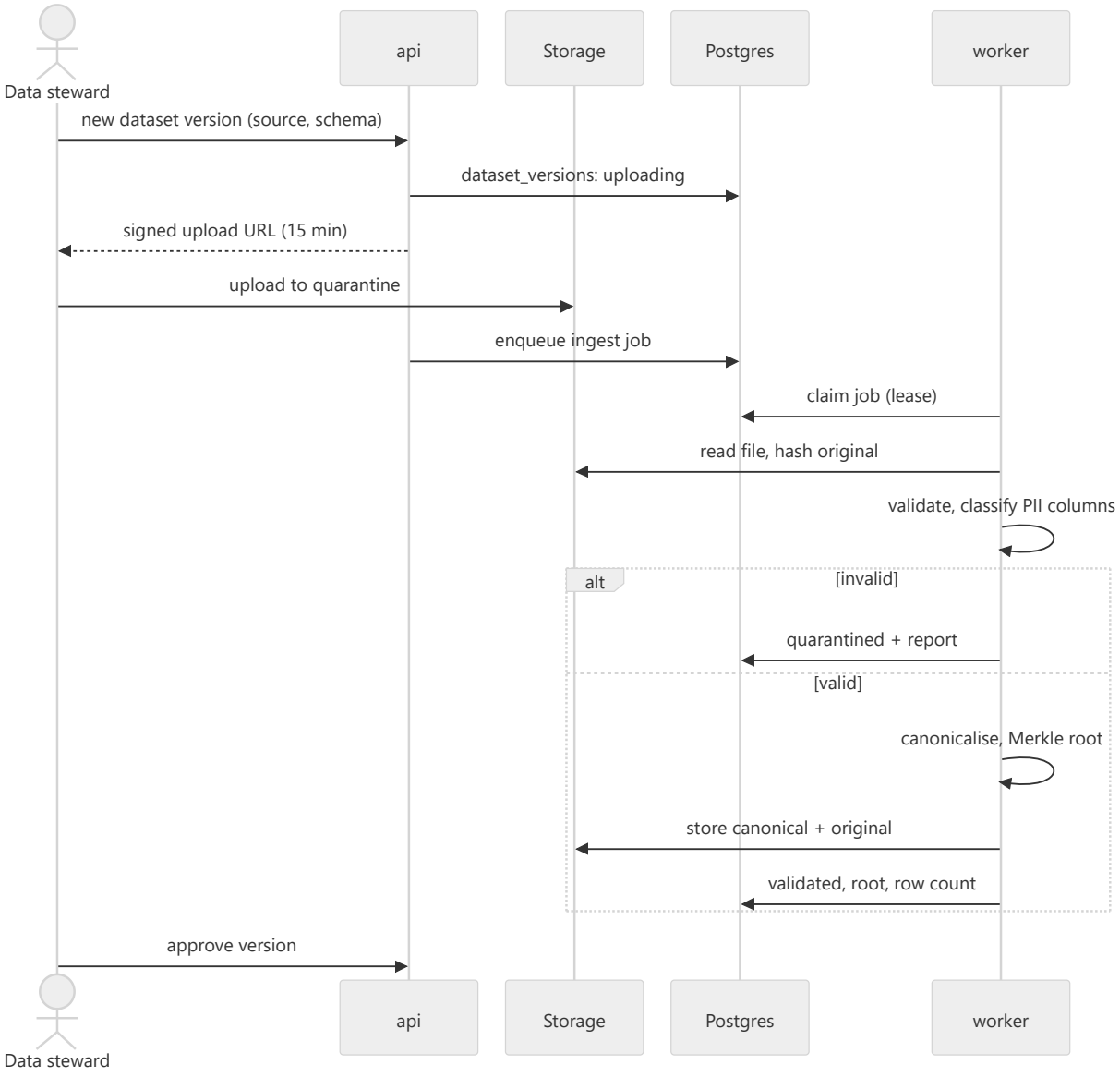
6. Data tiers

Tier	What	Where	Who can read
R — Restricted	Row-level roll data (synthetic in the MVP), dataset salts, row-level evidence (e.g. which two records look duplicated)	Private storage bucket, plus worker memory during a run	Worker; analysts and reviewers with `aal2` via short-lived signed URLs
I — Internal	Unpublished findings, review notes, ingestion reports, jobs, audit log, security events	Postgres, staff-only RLS	Staff by role and jurisdiction
P — Public	Approved aggregates (after suppression), published findings, methodology, manifests, anchors, booth data	Postgres with `published` RLS, plus the `public-artifacts` bucket	Everyone

Moving data from I to P happens **only** through publication: two-person approval, small-cell suppression, and an automated PII scan (Threat model §5).

7. Data flows

DF1 — Ingestion



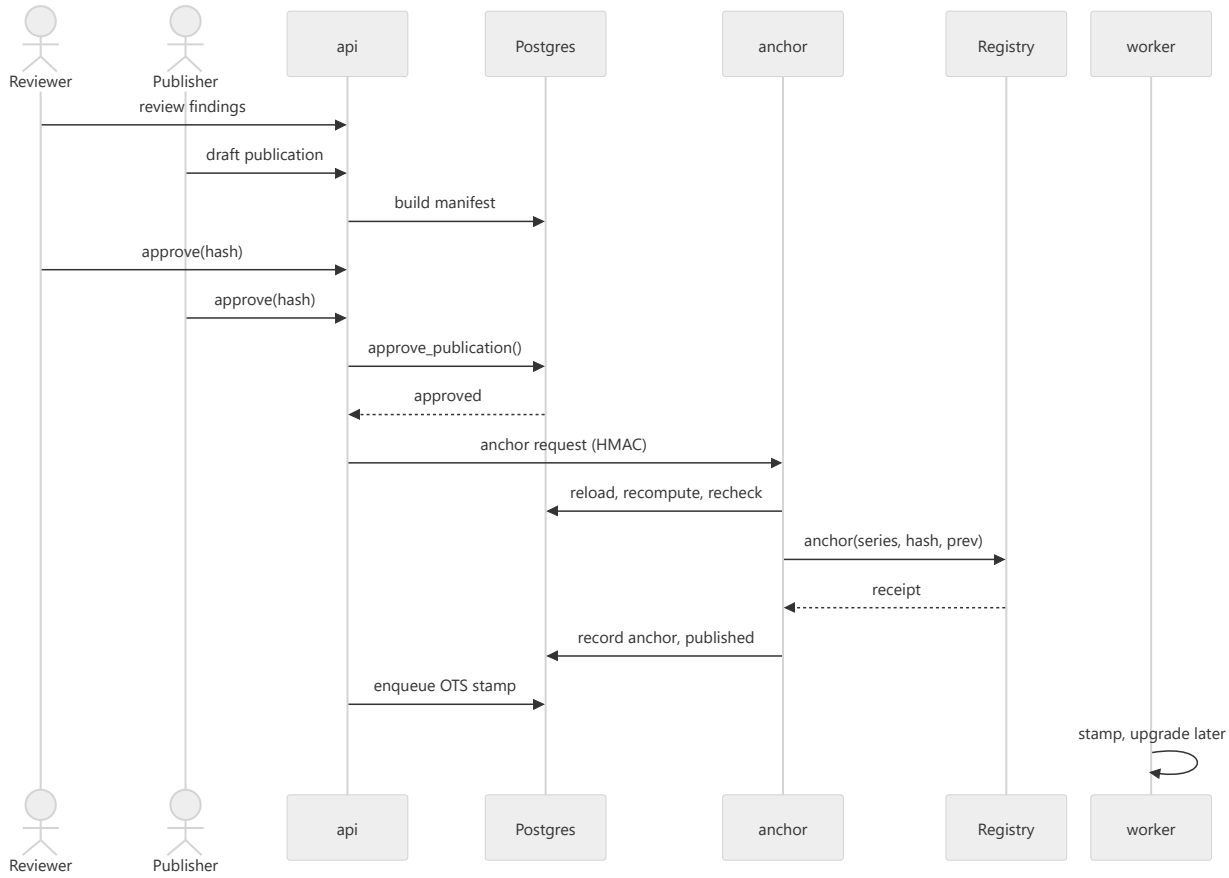
The file goes straight to Supabase Storage and never passes through the VPS. The worker claims jobs with `SKIP LOCKED` and a lease, validates schema, ranges and references, and stores the canonical Parquet next to the original in `datasets-restricted`. Every step is written to `audit_log`. Steward approval of a version is P1.

DF2 — Audit run

1. An analyst asks the API to run the audit on (baseline version, target version, methodology version). The API checks both versions are `approved` and enqueues `analyze`.
2. The worker loads both canonical files, diffs them, runs every rule on **every** part (FR-AUD-9), computes statistics with FDR control, and builds findings with evidence. Row-level evidence goes to restricted storage. Aggregate evidence goes to Postgres.
3. The worker renders explanations from templates in all three languages and records the code version, image digest, parameter hash and output hashes.

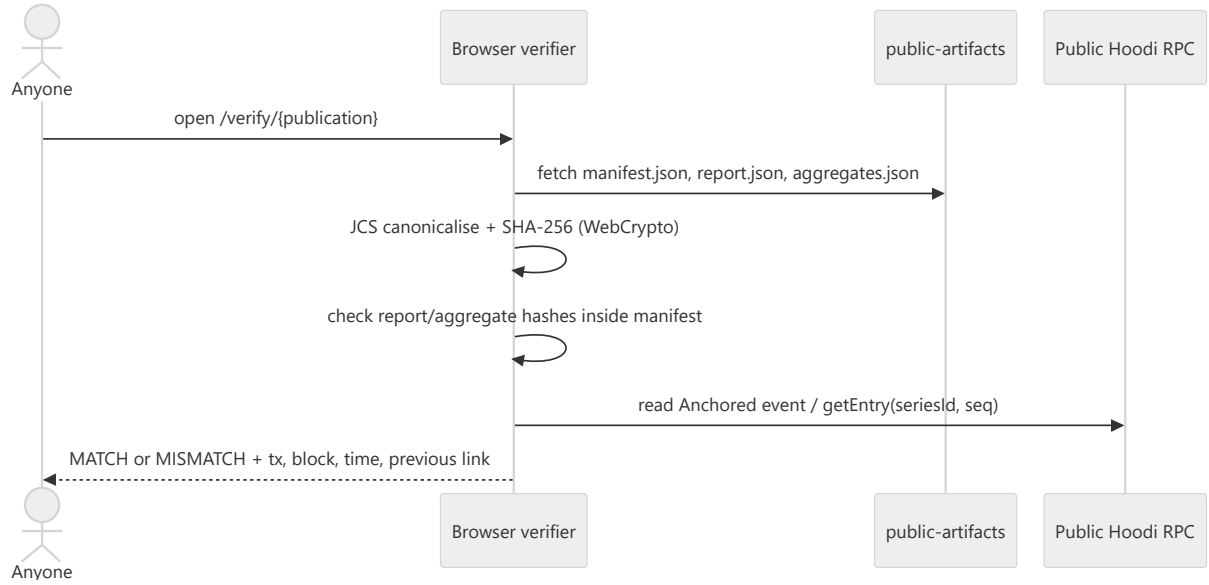
4. The run lands in `ready_for_review`. Nothing is public yet.

DF3 — Review, publication and anchoring



- Reviewers accept, downgrade or reject each finding with a reason. The draft manifest contains only suppressed aggregates and the report, and its `manifest_hash` is what both people approve.
- `approve_publication()` checks the roles, MFA (`aal2`), that the two approvers are different people, and that neither created the run.
- The anchor service is called on the internal network with an HMAC. It reloads the manifest, **recomputes the hash itself**, rechecks the approvals, then calls `anchor(seriesId, manifestHash, expectedPrevious)` on the Hoodi registry. The receipt (transaction, block, log index) goes into `blockchain_anchors`.
- The OpenTimestamps proof is upgraded once Bitcoin confirms it, which takes a few hours.
- Approvals bind to `manifest_hash`. If anything changes after an approval, the hash changes and the approvals no longer match.

DF4 — Independent verification (browser)



For synthetic datasets the canonical rows and salt are public too, so the verifier can rebuild the **dataset** Merkle root in the browser. For real restricted data, the public can verify reports and aggregates, and only authorised auditors can verify the dataset root (§8.5).

DF5 — Tamper demo (synthetic only)

In demo mode, the judge edits one record in a copy of the published synthetic dataset. The verifier recomputes the root, gets a different value, and highlights the mismatch next to the original anchor transaction. With an inclusion proof it also shows **which leaf** changed.

DF6 — Claim check

1. A user fills in the structured form, or free text is parsed into it by the LLM and confirmed by the user (P1). Turnstile is validated server-side.
2. The API maps the claim to a published aggregate query (area, metric, period).
3. Code computes the verdict with a stated tolerance: *Consistent* / *Contradicted* / *Disputed* (published sources disagree) / *Cannot be established*. Claims about intent or fraud always map to *Cannot be established*.
4. Templates render the explanation with the exact numbers and the manifest reference. If the user chose to submit the claim, it enters moderation. It is never auto-published.

DF7 — QR booth page

QR → `https://<subdomain>/b/{public_code}`. `public_code` is a random 10-character base32 value with no meaning. The page is server-rendered from `polling_stations` (published only) and shows source, last verified time and official links. The QR is generated by the API as SVG. Nothing personal is in the URL, the page or the logs.

8. Integrity design

8.1 Canonicalisation (`elcanon-1`)

1. Parse against the declared schema. Reject unknown or missing columns.
2. Strings: Unicode NFC, trimmed, internal whitespace collapsed to a single space, empty becomes `null` for optional fields. No case folding, except code fields the schema marks as uppercase.
3. Integers as JSON numbers. Dates as `YYYY-MM-DD`. Enums by code.

4. Each row becomes a JSON object serialised with **RFC 8785 (JCS)**, then UTF-8 encoded.
5. Rows are sorted by their canonical bytes (lexicographic), so file order and line endings don't matter.

8.2 Commitment

- Leaf: `SHA-256(0x00 ‖ salt ‖ row_bytes)`. Node: `SHA-256(0x01 ‖ left ‖ right)`. Tree shape is the RFC 6962 Merkle Tree Hash. The 0x00 and 0x01 prefixes prevent second-preimage tricks.
- `salt` is 32 random bytes per dataset version, kept in Tier R. It stops anyone from guessing a person's row and confirming it through a published inclusion proof. For synthetic datasets the salt is published.
- Reports and aggregates are public JSON: `SHA-256(JCS(doc))`.

8.3 Publication manifest

```
{
  "schema": "electralens.manifest.v1",
  "series_id": "DEMO-ST01-AC042",
  "sequence": 3,
  "previous_manifest_hash": "9f2c…",
  "is_synthetic": true,
  "datasets": [
    {"role": "baseline", "version_id": "…", "root": "…", "row_count": 184220, "schema": "electoral_roll_v1",
"canon": "elcanon-1"},
    {"role": "target",   "version_id": "…", "root": "…", "row_count": 179954, "schema": "electoral_roll_v1",
"canon": "elcanon-1"}
  ],
  "audit_run": {"id": "…", "engine": "git:<sha>", "image": "sha256:…", "methodology": "2026.1", "params_hash":
"…"},
  "report_hash": "…",
  "aggregates_hash": "…",
  "published_at": "2026-11-02T10:15:00Z",
  "publisher": "ElectraLens (independent, not affiliated with ECI)"
}
```

`manifest_hash = SHA-256(JCS(manifest))`. **One on-chain transaction per publication.**

8.4 Registry contract (interface sketch, full code in Deliverable F)

```
// Append-only. No update, no delete, no upgradeable proxy.
event Anchored(bytes32 indexed seriesId, uint256 indexed sequence, bytes32 indexed manifestHash, bytes32
previous, address publisher);
event Retracted(bytes32 indexed seriesId, bytes32 indexed manifestHash, bytes32 reasonHash, address publisher);

function anchor(bytes32 seriesId, bytes32 manifestHash, bytes32 expectedPrevious) external
onlyRole(PUBLISHER_ROLE);
//   reverts if manifestHash was already anchored, or expectedPrevious != latest(seriesId) (no forks, no races)
function retract(bytes32 seriesId, bytes32 manifestHash, bytes32 reasonHash) external onlyRole(PUBLISHER_ROLE);
function latest(bytes32 seriesId) external view returns (bytes32);
function entry(bytes32 seriesId, uint256 sequence) external view returns (bytes32 manifestHash, bytes32 previous,
uint64 timestamp, address publisher);
```

OpenZeppelin `AccessControl`. `DEFAULT_ADMIN_ROLE` stays in your MetaMask testnet wallet, never on the server. `PUBLISHER_ROLE` goes to the anchor hot wallet. If the server is compromised, you revoke the publisher role from MetaMask. Earlier entries can't be touched.

8.5 What goes on-chain, and what the chain does and doesn't prove

On-chain	Off-chain
`seriesId` (synthetic area code), sequence, `manifestHash`, previous hash, publisher address, block time, retraction reason **hash**	Datasets, salts, reports, aggregates, findings, the reason text, all personal data

It proves: whoever held the publisher key recorded hash *H* at block time *T*. Later entries can't silently change or remove it. Anyone can check that without trusting ElectraLens.

It does not prove: that the source data was authentic, complete or lawfully obtained; that the analysis was right; that the publisher was honest when publishing; that a testnet will exist forever (hence OpenTimestamps); or that restricted datasets match, unless an authorised auditor holds the data. Blockchain gives **consistency over time**, not truth.

9. Audit engine

9.1 Rule catalogue (thresholds are proposals, frozen per methodology version)

ID	Check	Method	Default criterion [P]	Innocent explanations shown
R01	Exact duplicate	Identical name, relative's name, age, gender and house number within a part (complete entries only; blanks are R10's concern)	Any match	Duplicate already pending deletion; re-registration after shifting; form entered twice
R02	Likely duplicate	Same phonetic key (`phonetic_key_v1`) for name and relative's name, same gender, age difference ≤ 2, within a part. Jaro-Winkler was tried and rejected: spelling variants score 0.80–0.88 and different names 0.82–0.91, so no threshold separates them	Any pair. Labelled "possible"	Transliteration variants; similar names; family members
R03	Impossible age	Age at qualifying date < 18 or > 110	Any	Data-entry error; age from a different qualifying date
R04	Age drift across versions	Same record, Δage ≠ elapsed years ± 1	Any	Correction through Form 8; earlier error fixed
R05	Deletion rate per part	Beta-binomial against a robust constituency baseline, Benjamini–Hochberg FDR. Transfers between parts are not deletions	q < 0.05 **and** rate ratio ≥ 2 **and** ≥ 20 deletions	House-to-house revision; migration or redevelopment; death-record catch-up; part reorganisation; duplicate clean-up
R06	Addition rate per part	Same as R05	Same	New housing; enrolment drive; first-time voters; part reorganisation
R07	Part appeared or disappeared	Structural diff	Any	Polling-station rationalisation (e.g. the 1,200 cap)
R08	High-occupancy address	Electors per normalised house number, compared with the constituency distribution	> p99.9 **and** ≥ 20	Hostels, institutions, joint families, placeholder house numbers ("0", "NA")
R09	Gender-ratio shift	Two-proportion test, FDR	q < 0.05 and |Δ| ≥ 50 per 1,000	Targeted enrolment; small part size
R10	Missing or invalid fields	Share of records per part, against the constituency	> p95 and ≥ 5 %	Data-entry quality in one batch

ID	Check	Method	Default criterion [P]	Innocent explanations shown
R11	Deletion-reason mix	Binomial test per reason against the other parts of the constituency, Bonferroni over the four reasons, then FDR (chi-square was unreliable with small expected counts)	q < 0.05 and share ratio ≥ 2 and ≥ 20 deletions	Local death-registration or verification drive
R12	18–19 cohort shift	Compared with the expected cohort	q < 0.05 and rate ratio ≥ 2	Enrolment camps near a qualifying date

9.2 Statistics, signal strength and uncertainty

- Overdispersion is modelled (beta-binomial). The baseline rate is the pooled rate of the constituency's middle 50 % of parts, and the dispersion comes from the median absolute deviation of the residuals. Large parts don't fire on trivial differences, and a few extreme parts can't hide themselves by inflating the baseline.
- **FDR control** across thousands of parts (Benjamini–Hochberg), because testing many parts guarantees some false alarms. Every finding shows how many tests were run.
- A minimum effect size goes alongside significance.
- **Signal strength**, not "confidence of fraud": *Strong* (q < 0.001, rate ratio ≥ 3), *Moderate* (q < 0.01, rate ratio ≥ 2), *Weak* (q < 0.05, staff-only), *Data-quality notice*. Each comes with the observed value, the expected value, a 95 % Wilson interval and the q-value.
- The methodology page states plainly: "*Signal strength says how unusual a pattern is compared with similar areas. It is not the probability that anything improper happened.*"

9.3 Explainability output (per finding)

```
{
  "finding_id": "F-2026-000123",
  "rule": {"id": "R05", "version": "1.0.0", "name_key": "rule.R05.name"},
  "datasets": {"baseline": "…", "target": "…"},
  "area": {"level": "part", "code": "DEMO-ST01-AC042-P047"},
  "evidence": {"deletions": 212, "electors_baseline": 1180, "rate": 0.1797, "rate_ci95": [0.159, 0.202],
               "expected_rate": 0.061, "rate_ratio": 2.95, "q_value": 0.0004, "tests_in_run": 2140},
  "baseline": {"type": "constituency_parts", "n_parts": 286, "method": "beta_binomial"},
  "criterion": "q<0.05 AND rate_ratio>=2 AND deletions>=20",
  "signal_strength": "moderate",
  "explanation": {"en": "…", "hi": "…", "xx": "…"},
  "alternative_explanations": ["alt.house_to_house", "alt.migration", "alt.part_reorg"],
  "limitations": ["lim.synthetic_data", "lim.no_reason_codes"],
  "review": {"status": "accepted", "reviewed_at": "…"},
  "label": "analytical_finding"
}
```

9.4 Reproducibility and measuring detection quality

- Polars, sorted inputs, a fixed seed and pinned dependencies. Outputs are hashed. A CI "golden run" fails if output hashes drift without a methodology version bump.
- The synthetic generator writes a **ground-truth file** of injected anomalies. A benchmark job computes precision and recall per rule, and they go on the methodology page (FR-AUD-7). This is also how we decide whether ML is worth adding (FR-AUD-8).
- **Measured so far** (methodology 2026.1, seeds 42, 7 and 2026, about 110,000 electors each): every injected anomaly found, no false positives, no negative control violated. This is an easy test: the injected patterns are 2–5 times the

normal rate, and the generator never creates two indistinguishable people in one part. Real data and subtler patterns will be harder, and the methodology page says so.

10. Authentication and authorisation

10.1 Who signs in how

- **Public:** no account.
- **Citizen:** Supabase Auth with Google OAuth or an email magic link (custom free SMTP). Turnstile on sign-in. Only a profile row is stored. **No EPIC number anywhere.** EPIC numbers are printed on cards and shared openly, so they are identifiers, not secrets.
- **Staff:** invite-only. A system admin invites through the API, which uses the service role to create the user and an assignment. Email + password (≥ 14 characters) + **mandatory TOTP**. Public signup can never create a staff role, because roles live in `staff_assignments`, which only the admin workflow writes.

10.2 Role matrix

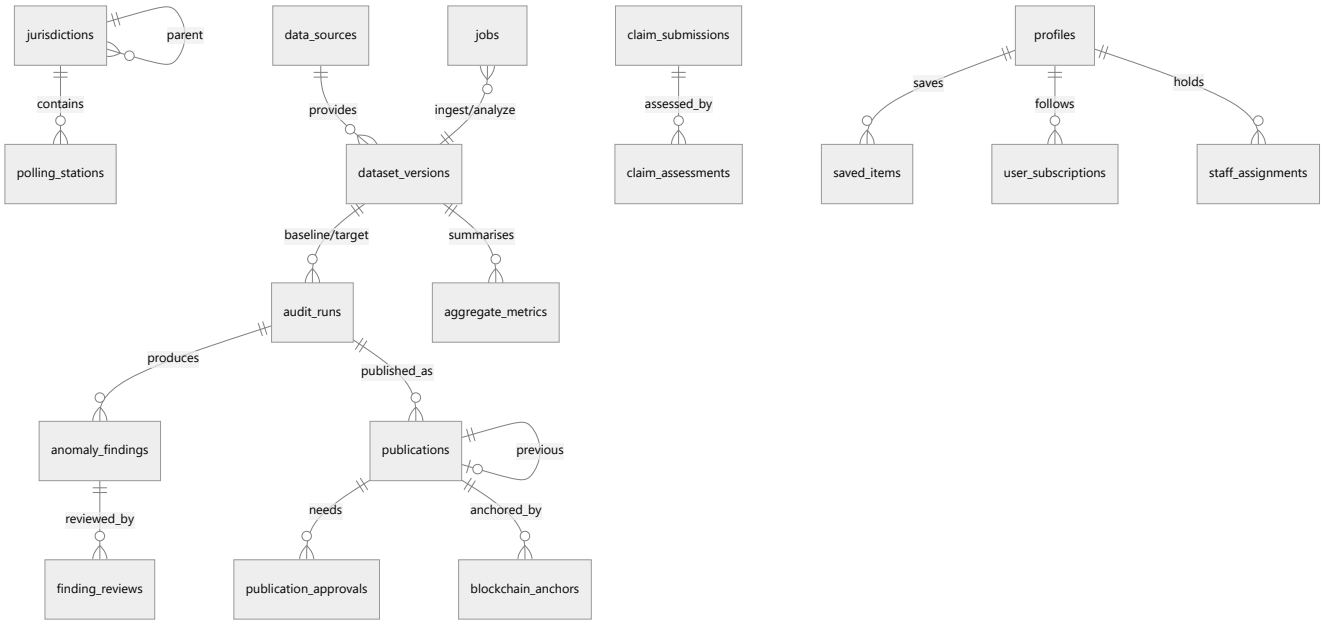
Capability	steward	analyst	reviewer	publisher	auditor	sysadmin
Upload or approve dataset versions	✓					
Run audits, view restricted evidence		✓	✓ (read)			
Review findings			✓ (not own run)			
Approve publication — review step			✓			
Approve publication — publish step, retract				✓ (not own review)		
Manage booth data	✓					
Read audit log and security events					✓	✓
Invite staff, assign or revoke roles						✓

One person may hold several roles in a small team, but **the database requires distinct people** for run creator, reviewer approval and publisher approval on the same publication.

10.3 How RLS and the API work together

1. **RLS is the floor.** Every table has RLS enabled. Anonymous users get `select` on published rows only. Staff policies call `security definer` helpers such as `el.has_role(role, jurisdiction)` that read `staff_assignments` **and** require `auth.jwt()->>'aal' = 'aal2'`. Revoking a role therefore works on the next query, not when the token expires. JWT role claims from the hook are UI hints only.
2. **The API is the front door.** It checks role and MFA again for clear errors, applies rate limits and Turnstile, and writes the audit log. For user actions it calls Supabase **with the user's JWT**, so RLS applies as well. The service role is used only in a few named system functions (invites, job state, publication assembly).
3. **Workflow transitions are database functions** (`approve_publication`, `retract_publication`, `review_finding`). Each checks the state machine and separation of duties and writes `audit_log` in the same transaction, so no client, including our own API, can skip a step.
4. **Sessions:** web uses `@supabase/ssr` httpOnly cookies. Calls to the API carry a bearer token, so they aren't exposed to CSRF. Staff sessions use short idle timeouts in the UI. Login abuse is handled by Supabase Auth rate limits, Turnstile, and `security_events` logging with alerts.

11. Data model (refined from the brief)



How this differs from the brief's list, and why:

Brief	Decision
`ingestion_jobs`, `analysis_jobs`, `publication_jobs`	One `jobs` table with `kind`. Same queue logic, less code.
`source_manifests`	Covered by `data_sources` + `dataset_versions` (provenance) and `publications.manifest` (the published manifest).
`staff_roles`	A Postgres enum. Roles are fixed by the design, and assignments live in `staff_assignments`.
`review_actions`	`finding_reviews` for findings. Every other action goes to `audit_log`.
`saved_reports`	`saved_items` (reports **and** booths).
`retention_policies`	A versioned config file plus a scheduled job, published on the privacy page. A table would add nothing.
(new) `publications`	The manifest, status machine and previous-version link. The centre of governance.
`security_events`, `incident_records`, `audit_log`, `claim_*`, `blockchain_anchors` (EVM and OTS via `anchor_type`)	Kept.

Full SQL, constraints, indexes, RLS and pgTAP tests come in Deliverable C.

12. API surface (overview, full contracts in Deliverable D)

All routes under `/api/v1`. Errors use RFC 9457 `application/problem+json`. Requests and responses are validated with shared schemas.

- **Public:** `GET datasets`, `GET datasets/{id}/summary`, `GET comparisons?baseline=&target=`, `GET findings`, `GET findings/{id}`, `GET methodology/{version}`, `GET publications`, `GET publications/{id}/manifest`, `GET verify/{id}` (convenience only, since the browser verifier doesn't need it), `GET booths/{code}`, `GET booths/{code}/qr.svg`, `POST claims/check` (Turnstile, rate-limited), `GET official-links`.

- **Citizen:** `GET/PATCH me`, `GET/POST/DELETE me/saved`, `GET/POST/DELETE me/subscriptions`, `DELETE me`.
- **Staff** (JWT + `aal2` + role): `POST staff/datasets`, `POST staff/datasets/{id}/approve`, `POST staff/runs`, `GET staff/runs/{id}`, `POST staff/findings/{id}/review`, `POST staff/publications`, `POST staff/publications/{id}/approve`, `POST staff/publications/{id}/retract`, `POST staff/users/invite`, `PUT staff/users/{id}/roles`, `GET staff/audit-log`, `GET staff/security-events`, `GET staff/jobs`, `POST staff/booths/import`.
- **Internal:** anchor `POST /internal/anchor` (Docker network only, HMAC with timestamp and nonce).

13. Trust boundaries

ID	Boundary	Control
TB1	Internet → edge	Cloudflare WAF, rate limits, Turnstile
TB2	Edge → VPS	nginx accepts only Cloudflare IPs for this host. TLS Full (strict).
TB3	nginx → containers	Ports bound to 127.0.0.1. Body size limits.
TB4	api → anchor	Internal network only. HMAC. Anchor re-validates everything.
TB5	Services → Supabase	Credentials split: anon (web), user JWT and service role (api), worker role (worker)
TB6	Restricted/internal → public	Publication gate: two-person approval, suppression, PII scan
TB7	ElectraLens → chain and OTS	Public and permanent. Hashes and IDs only.
TB8	ElectraLens → LLM provider	Public evidence only, output validated, template fallback
TB9	Browser verifier vs our server	The verifier reads the chain directly and doesn't trust our API
TB10	ElectraLens vs the other app on the same VPS	Separate compose project, network, Unix user, directories, secrets and resource limits

14. Failure handling

Failure	Behaviour
Supabase unreachable or paused	Public pages serve cached copies with a "data as of …" banner. Writes fail closed. Alert.
Worker crash mid-job	Lease expires and the job is retried (max 3, idempotent by input hashes), then dead-lettered with an alert. Outputs are staged and committed in one transaction, never half-published.
Analysis too slow or too big	Container memory and time limits kill it, the job is marked failed, nothing is published.
RPC down or transaction stuck	Publication shows "integrity anchor pending". Anchor retries with backoff and bumps the fee on replacement. Alert after 1 hour.
Testnet retired or reset	OpenTimestamps proofs remain valid. History is re-anchored on a new network with a migration manifest that cites the old transaction hashes.
OTS calendar down	Several calendars are used. Upgrade retried later.
LLM unavailable, rate-limited or output rejected	Template text (always available).
Turnstile unavailable	Claim submission pauses (fail closed). Reading is unaffected.
Malformed or malicious upload	Quarantine plus ingestion report. Parser in a non-root, read-only container.
Unauthorised on-chain anchor	A reconciliation job compares chain events with approved publications and raises a critical alert (Threat model T16).
Traffic spike	Cached public pages at the edge, API rate limits, claim checks queued.

Failure	Behaviour
VPS disk filling	Docker log rotation, alert at 80 %.

15. Deployment on the VPS

- Path `/opt/electralens`, compose project `electralens`, separate Unix user, completely apart from the other app.
- Services `web`, `api`, `worker`, `anchor`: `restart: unless-stopped`, healthchecks, `mem_limit` and `cpus`, non-root, `read_only: true` with tmpfs `/tmp`, `cap_drop: [ALL]`, `no-new-privileges`. Only web (3100) and api (4100) publish ports, both on **127.0.0.1**. The other app uses 8080/8443, so these don't clash.
- Secrets in Docker `secrets:` files (`chmod 600`). Each service gets only its own: web never sees the service-role key, and only anchor has the chain key. No secrets in Git or in `NEXT_PUBLIC_*` variables.
- Host nginx: a new `electralens.conf` server block with TLS (Let's Encrypt via certbot, or a Cloudflare Origin CA certificate), HSTS, CSP, `X-Content-Type-Options`, `Referrer-Policy`, `Permissions-Policy`, `client_max_body_size 1m` (uploads go straight to Supabase Storage), `limit_req` zones, and the Cloudflare IP allow-list **for this server block only**. The other app's configuration is untouched.
- **Backups:** nightly `pg_dump` (custom format, client version matching Supabase's Postgres major [A]) → encrypted with `age` to a public key whose private key lives **off** the VPS → 14 daily and 8 weekly copies kept → weekly copy pulled off the VPS (decision D7). Monthly restore drill into the local Supabase CLI. Synthetic datasets can be regenerated from their seeds.
- **Monitoring:** `/healthz` and `/readyz`, container healthchecks, a free external uptime monitor, job-failure and reconciliation alerts by email (and optionally a Telegram bot).
- **CI/CD:** GitHub Actions runs lint, typecheck, unit tests, Python tests, contract tests, RLS tests (local Supabase in CI), cross-language canonicalisation vectors, the PII scan, and image builds tagged by Git SHA. Deploy is SSH → pull tag → `docker compose up -d`. Migrations are applied manually and are additive only (expand, migrate, contract).
- **Rollback:** `IMAGE_TAG=<previous> docker compose up -d`. Because migrations are additive, rolling back the app never needs a database rollback. Database restore is for disasters only.

16. Repository structure

```
electralens/
├─ apps/
│  ├─ web/          Next.js (App Router, TS): public portal, assistant, verifier, citizen pages, ops console
│  └─ api/          Fastify (TS): REST API, authz, Turnstile, rate limits, audit log, QR
├─ services/
│  ├─ engine/       Python: generator, canonicaliser, rules, stats, templates, reports, worker loop, OTS
│  └─ anchor/       Node + ethers v6: signer service (the only holder of the testnet key)
├─ packages/
│  ├─ canon/        TS canonicaliser + Merkle + manifest (shared by browser verifier and api)
│  ├─ schemas/      JSON Schemas → TS (zod) and Python (pydantic) types
│  └─ i18n/         en / hi / third-language catalogues and explanation templates
├─ contracts/       Hardhat project: ElectraLensRegistry.sol, tests, deploy scripts
├─ supabase/        migrations/, seed.sql (fictional), tests/ (pgTAP RLS tests), config.toml
├─ test-vectors/    canonicalisation vectors used by both Python and TS tests
├─ infra/           docker-compose.yml, nginx/electralens.conf, backup/, scripts/
├─ docs/
└─ .github/workflows/
```

Hardhat rather than Foundry: it's TypeScript-native, uses ethers (as the brief asks), and runs natively on Windows.

PART 3

ElectraLens — Threat Model and Privacy-by-Design Review

Version 0.1 · 2026-10-27 · Draft for approval. Component and boundary names (TB1–TB10) as in 02-ARCHITECTURE.md.

No single control here makes the system secure. Cloudflare, RLS, encryption and blockchain are each one layer. The plan assumes every layer can fail and asks what the next one catches.

1. Scope and assets

Asset	Why it matters
A1 Restricted row-level data and salts	Personal data in a real deployment. Leaking it is the worst outcome.
A2 Publication integrity (what was published, and when)	The product's credibility
A3 Neutrality and accuracy of public findings	A wrong or slanted finding can mislead voters and be weaponised
A4 Staff accounts and roles	The route to A1–A3
A5 Anchor publisher key	Can append to the public record
A6 Supabase service-role key	Bypasses RLS
A7 Citizen accounts (email, saved items)	Personal data under the DPDP Act
A8 Availability during roll-revision periods	Peak interest is exactly when attacks are likely
A9 The other app on the same VPS	Shared blast radius (TB10)

2. Adversaries

- **Partisan actors** of any side who want either to suppress inconvenient findings or to manufacture "proof" of wrongdoing.
- **Scrapers and data brokers** after personal data.
- **Opportunistic attackers:** credential stuffing, scanners, bots.
- **Malicious or careless insiders:** staff with legitimate access.
- **Misinformation spreaders** who screenshot or misquote outputs out of context.
- **Supply-chain attackers:** compromised npm or PyPI packages, Docker images.

3. Threats

Format: **Scenario** · **Impact** · **Prevent** · **Detect** · **Recover** · **Residual risk** (L/M/H).

T01 Unauthorised staff access

- Scenario: a citizen signs up and tries to reach staff routes, or edits `user_metadata` to claim a role.
- Impact: access to A1/A3.
- Prevent: roles come only from `staff_assignments`, written only by the admin workflow; RLS requires `has_role()` **and** `aal2`; staff routes check again server-side; there is no role field in signup.
- Detect: `security_events` on 403s to staff routes; alert on repeats.
- Recover: revoke sessions, review the audit log.
- Residual: **L**.

T02 Compromised administrator account

- Scenario: phished password, or a stolen session cookie.
- Impact: role escalation, invites for attacker accounts.
- Prevent: mandatory TOTP; sysadmin **cannot** publish or review (separation of duties); every role grant is logged and emailed to all admins; short staff sessions.
- Detect: alert on role grants, new MFA factor enrolment, logins from new locations.
- Recover: revoke the factor and sessions from a second admin; rotate the service-role key if exposure is suspected; audit everything since the compromise.
- Residual: **M** (a single founder-admin is a real gap until there are two admins).

T03 Malicious or malformed dataset upload

- Scenario: CSV injection (`=HYPERLINK(...)`), decompression bombs, a huge file, a hostile Parquet file, path tricks in file names.
- Impact: worker crash or resource exhaustion; formula execution when staff open exports in Excel.
- Prevent: allow-listed types, size limits, schema-first parsing (Polars with explicit dtypes), server-generated storage paths, worker runs non-root and read-only with memory and time limits, CSV exports escape leading `= + - @` characters.
- Detect: quarantine reports; job failure alerts.
- Recover: delete the quarantined object (logged); fix the parser and retry.
- Residual: **L**.

T04 SQL injection

- Scenario: crafted filters on public endpoints.
- Impact: data exposure.
- Prevent: the Supabase client and parameterised queries only; no string-built SQL; RLS limits damage even if injection happened; database functions use `set search_path = ''`.
- Detect: WAF managed rules (free set); error-rate alerts.
- Recover: patch, review logs.
- Residual: **L**.

T05 Broken authorisation / IDOR

- Scenario: `GET /me/saved/{id}` returns another user's row; an analyst reads another jurisdiction's restricted evidence.
- Impact: privacy breach.
- Prevent: RLS `user_id = auth.uid()` and jurisdiction scoping; the API uses the user's JWT, not the service role, for user data; random UUIDs; pgTAP tests for every policy (PRD AC-4).
- Detect: tests in CI; 403 and 404 anomaly monitoring.
- Recover: hotfix the policy; notify affected users if exposure is confirmed.
- Residual: **L–M** (until the policy tests are complete).

T06 Cross-site scripting

- Scenario: a malicious claim text, dataset field or translation string rendered as HTML.
- Impact: session theft, especially of staff sessions.
- Prevent: React escaping; no `dangerouslySetInnerHTML` on user content; strict CSP with nonces; httpOnly cookies; templates interpolate values as text only.
- Detect: CSP violation reports; lint rule bans raw HTML.
- Recover: patch, rotate staff sessions.
- Residual: **L**.

T07 CSRF

- Scenario: a third-party page triggers state changes using a logged-in user's cookies.
- Impact: unwanted saves or subscriptions; staff actions in the worst case.
- Prevent: the API only accepts bearer tokens (no cookie auth); web server actions check `Origin`; SameSite=Lax cookies.
- Detect: Origin-mismatch logging.
- Recover: n/a.
- Residual: **L**.

T08 SSRF via URL imports

- Scenario: "import from URL" pointed at `169.254.169.254` or internal services.
- Impact: internal network access.
- Prevent: **no URL import in the MVP** (FR-ING-8). If added later: host allow-list, DNS pinning, private-IP blocking, no redirects.
- Detect: n/a in the MVP.
- Recover: n/a.
- Residual: **L**.

T09 Credential stuffing and brute force

- Scenario: botnets try leaked passwords on staff and citizen logins.
- Impact: account takeover.
- Prevent: Supabase Auth rate limits; Turnstile on sign-in; citizens mostly use OAuth or magic links (no passwords); staff need TOTP anyway; Cloudflare rate-limit rule on auth paths.
- Detect: `security_events` spikes; alert.
- Recover: lock affected accounts, force a reset.
- Residual: **L**.

T10 Abuse of public APIs

- Scenario: scraping everything, hammering the claim checker, flooding claim submissions.
- Impact: cost (free-tier quota exhaustion), degraded service, spam.
- Prevent: everything public is aggregate and meant to be public anyway; caching; per-IP limits in Fastify and nginx plus one Cloudflare rule; Turnstile on POSTs; pagination caps; claim submissions moderated.
- Detect: rate-limit metrics; Supabase usage dashboard.
- Recover: tighten limits, block ASNs at the edge.
- Residual: **M** (free-tier quotas are the weak point, not data exposure).

T11 Privacy leakage through aggregates

- Scenario: small cells ("1 woman aged 90+ deleted in part 47"), or **differencing** between two releases or two overlapping breakdowns.
- Impact: re-identification.
- Prevent: suppression rules in §5.3; only pre-defined breakdowns (no ad-hoc query API); consistent rounding; release-diff check before publication.
- Detect: automated disclosure check in the publication pipeline that blocks failing releases.
- Recover: retract and republish with a documented reason.
- Residual: **M**.

T12 Re-identification by combining with other data

- Scenario: someone joins our part-level outputs with a scraped roll PDF.
- Impact: we'd be enabling profiling.

- Prevent: we never publish row-level data, quasi-identifier combinations or fine geography (no coordinates for individuals; booth coordinates only); suppression; salted Merkle leaves; no inclusion proofs for real data in public.
- Detect: periodic disclosure review.
- Recover: retract.
- Residual: **M** for real data (it's an inherent risk of any aggregate release), **none** for synthetic data.

T13 Blockchain metadata leakage

- Scenario: on-chain series IDs, timing or retraction reasons reveal more than intended; people later want something "erased".
- Impact: permanent disclosure.
- Prevent: only hashes and synthetic or official area codes go on-chain; reasons as hashes; salted dataset roots; synthetic series are prefixed `DEMO-`.
- Detect: a review checklist before the first real-data anchor.
- Recover: **none on-chain**, which is why only hashes go there.
- Residual: **L**.

T14 Incorrect or fraudulent source data

- Scenario: a fabricated "roll" is uploaded to manufacture a finding, or a genuine source contains errors.
- Impact: false findings with a credible-looking integrity proof.
- Prevent: provenance required (source URL, retrieval time, original checksum, permission basis); steward approval; findings labelled with their source; the methodology page states that **integrity ≠ authenticity**; synthetic data is watermarked everywhere.
- Detect: cross-checks against published official totals where available.
- Recover: retraction with a reason, linked from every affected page.
- Residual: **M**. This is the limit blockchain can't fix.

T15 AI hallucination or biased wording

- Scenario: LLM text invents numbers, names a party, or says "fraud"; a translation shifts the meaning.
- Impact: misinformation under our name.
- Prevent: templates by default; the LLM only sees public evidence JSON; a validator checks every number and place against the evidence; banned-term and named-entity filter; template fallback; verdicts and statistics always come from code; human-reviewed translations.
- Detect: validator rejection metrics; user "report a problem" link.
- Recover: disable the LLM flag instantly; correct and republish.
- Residual: **L** with the LLM off, **M** with it on.

T16 Unauthorised publication

- Scenario: an insider or a compromised API publishes without review, or calls the contract directly with the hot key.
- Impact: false or unreviewed findings go public and get anchored.
- Prevent: the two-person rule enforced in the database; approvals bind to `manifest_hash`; the anchor service re-checks approvals; the contract's publisher role can be revoked from the offline admin wallet.
- Detect: a **reconciliation job** that compares every `Anchored` event with approved publications and raises a critical alert on any orphan.
- Recover: revoke the publisher role, `retract()` with a reason, publish an incident note.
- Residual: **L–M**.

T17 Compromised signing key

- Scenario: the VPS is breached and the anchor key stolen.
- Impact: bogus anchors (testnet, so no money is lost).

- Prevent: the key exists only in the anchor container's secret; the anchor service has no published port; the admin role is offline; the wallet holds a minimal balance.
- Detect: reconciliation (T16); balance and nonce monitoring.
- Recover: the admin revokes the role, a new key is generated and granted, orphan anchors are retracted.
- Residual: **L** (history before the compromise stays intact).

T18 Database deletion or ransomware

- Scenario: a leaked service-role key or a malicious insider drops tables.
- Impact: loss of the operational record. (Published manifests survive on-chain and in OTS proofs.)
- Prevent: least-privilege roles; service role only in the API; no destructive endpoints; the audit log has UPDATE and DELETE revoked.
- Detect: row-count and health monitors.
- Recover: restore from the nightly encrypted dump (**recovery point up to 24 hours, because the free tier has no point-in-time recovery**); verify the restore against on-chain manifests.
- Residual: **M** (24 h recovery point is the zero-cost trade-off).

T19 Outage during high traffic

- Scenario: roll publication day, a news cycle, or a DDoS.
- Impact: unavailable exactly when needed.
- Prevent: Cloudflare caching and DDoS absorption (if D3 = yes); static and ISR public pages; minimal JS; API rate limits.
- Detect: uptime monitor.
- Recover: serve cached pages only; temporarily disable the claim checker.
- Residual: **M** (single VPS). **H** if D3 = no, because there's then no edge cache or DDoS absorption.

T20 Malicious insider

- Scenario: a reviewer suppresses an inconvenient finding, or an analyst tunes thresholds to create one.
- Impact: biased output (A3).
- Prevent: methodology versions frozen and public **before** runs; every run covers every part (no cherry-picking); rejections require a reason and are counted publicly per run ("12 findings, 3 rejected by review"); separation of duties.
- Detect: the auditor role; public rejection counts; methodology change log.
- Recover: re-review by different staff; correction notice.
- Residual: **M**.

T21 Insecure backups

- Scenario: a dump is left readable on the VPS or copied to an insecure place.
- Impact: bulk data leak.
- Prevent: `age` encryption with an **off-server** private key; `chmod 600`; no backups in Git; synthetic-only in the MVP.
- Detect: periodic permission check.
- Recover: rotate the key, re-encrypt.
- Residual: **L**.

T22 Shared VPS blast radius

- Scenario: a compromise of the other app reaches ElectraLens, or the other way round.
- Impact: cross-project breach.
- Prevent: separate Unix users and directories, separate compose networks, non-root, read-only containers, no shared secrets, nginx server blocks isolated.
- Detect: host auditd or fail2ban logs.

- Recover: rebuild containers, rotate both projects' secrets.
- Residual: **M** (same kernel, same host).

T23 Supply-chain compromise

- Scenario: a malicious npm or PyPI update, or a poisoned base image.
- Impact: code execution with service secrets.
- Prevent: lockfiles; pinned versions and image digests; Dependabot alerts (free); minimal dependencies; `npm ci` / `pip install --require-hashes`.
- Detect: `npm audit` / `pip-audit` in CI.
- Recover: roll back the image, rotate secrets.
- Residual: **M**.

T24 Misuse and misrepresentation of outputs

- Scenario: a finding screenshot is shared as "ElectraLens proves fraud in X".
- Impact: harm to A3; political weaponisation.
- Prevent: every finding page and image carries its label, signal strength, alternative explanations and a permalink; share cards include "an anomaly is not evidence of wrongdoing"; neutral language rules.
- Detect: monitoring mentions (manual).
- Recover: a public clarification linked from the finding.
- Residual: **M**. It can be reduced, not eliminated.

T25 Impersonation of ECI

- Scenario: users mistake ElectraLens for an official portal, or a phishing site copies ours.
- Impact: misplaced trust, legal exposure.
- Prevent: no ECI logos or emblem; a persistent "independent, not affiliated with ECI" notice; official links clearly marked as external.
- Detect: user reports.
- Recover: adjust wording; takedown requests for copies.
- Residual: **L**.

4. Security testing plan (feeds Milestone 8)

- pgTAP RLS suite: every table × {anon, citizen, each staff role, staff without `aal2`}.
- API authorisation tests for every route × role, including IDOR attempts.
- Separation-of-duties tests (PRD AC-5).
- Contract tests: no overwrite, no duplicate hash, wrong previous hash reverts, role revocation, retraction event.
- Cross-language canonicalisation vectors (PRD AC-7).
- Fuzzing the upload validator with malformed CSV and Parquet files.
- PII scanner over public API responses and published files (PRD AC-3).
- Disclosure-control tests on aggregates (small cells, differencing).
- OWASP ZAP baseline scan against staging (free).
- Restore drill from backup, timed.
- Manual review: CSP, headers, secrets placement, Docker hardening.

5. Privacy-by-design review

5.1 Data inventory

Data	Tier	Purpose	Retention [P]	Access
Synthetic roll rows	R	Demo and benchmark	Kept (not personal data)	Worker, analysts; public for demo datasets
Real roll rows (future, only after D9)	R	Analysis	Shortest needed; deleted 90 days after the final report unless a legal hold applies	Worker, scoped analysts
Dataset salts	R	Inclusion-proof privacy	Same as dataset	Worker
Aggregates and findings (published)	P	Transparency	Permanent (public record)	Everyone
Citizen email and OAuth ID	Auth	Sign-in	Until account deletion	The user; system
Citizen profile, saved items, subscriptions	I (own-row RLS)	Features	Until deletion	The user
Claim submissions (text)	I → P after moderation	Claim checking	1 year if unpublished	Moderators
Server and nginx logs (IP, user agent)	I	Security	14 days	Sysadmin, auditor
`security_events`	I	Abuse detection	180 days	Auditor, sysadmin
`audit_log`	I	Accountability	Permanent (append-only, no personal data beyond staff IDs)	Auditor
Voice input	Browser	Assistant	Not stored by ElectraLens. The browser's speech service may process audio [A: depends on the browser]	—

5.2 Principles as applied

- **Minimisation:** no EPIC numbers, no phone numbers, no dates of birth for citizens. Staff need only email and MFA.
- **Purpose limitation:** restricted data is used only for the audit run it was approved for.
- **No unofficial personal lookup:** "Is my name on the roll?" always links to the official service.
- **Defaults:** no analytics trackers and no third-party scripts except Turnstile on the pages that need it. Self-hosted fonts.
- **Transparency:** a public privacy page lists exactly this inventory and the retention rules.

5.3 Disclosure control for public aggregates

1. No public breakdown below part level.
2. Any cell with **1 to 9** people is suppressed and shown as "< 10" (threshold k = 10 [P], configurable per methodology version).
3. Complementary suppression, so a suppressed cell can't be recovered from row or column totals.
4. Cross-tabs (age band × gender × reason) only at constituency level and above.
5. A **release-differencing check**: before publishing version n, simulate subtracting it from version $n-1$ and from overlapping breakdowns, and block if any derived cell is below k.
6. Rounding to the nearest 5 for sub-constituency cross-tabs [P].
7. Synthetic data goes through the same rules, so the demo shows the real behaviour.

5.4 QR and booth pages

QR codes contain only `/b/{random code}`. Booth pages contain public facility information only. No per-voter QR codes. Page views are not linked to accounts.

5.5 Legal notes (not legal advice)

- The **DPDP Act 2023** applies to digital personal data. The **DPDP Rules 2025** were notified in November 2025 and phase in over about 18 months, with the main obligations from around May 2027 [V, secondary sources; check the Gazette].
- Citizen accounts are personal data: we need a clear notice, a stated purpose, easy deletion (FR-ACC-3) and breach handling.
- Synthetic data isn't personal data. **Real roll data is personal data even when officially published.** Republishing or processing it at scale needs legal review first (decision D9).
- ElectraLens is not affiliated with ECI and doesn't use ECI marks.

5.6 Responsible AI and neutrality

- **Code computes, AI explains.** No model decides a finding, a verdict or a signal strength.
- No party, candidate or vote-share data is ingested, which removes the most direct route to partisan framing.
- Uniform rules for every area; methodology published before results; public counts of rejected findings.
- Banned-term filter and fluent-speaker review for all three languages.
- Every finding shows innocent explanations with the same prominence as the evidence.
- A visible correction and retraction history.

PART 4

ElectraLens — Implementation Roadmap

Version 0.1 · 2026-10-27 · Draft for approval. IDs refer to 01-PRD.md, 02-ARCHITECTURE.md and 03-THREAT-MODEL.md.

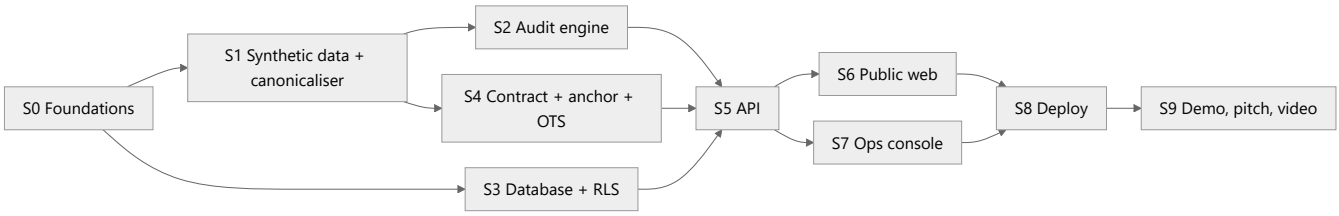
1. Assumptions behind this plan

- The hackathon is **24 hours** and the result must be production-grade (PRD C7). The start time, team size, official judging criteria, and whether any code may be prepared before the clock starts are still **unknown** (decision D10).
- [A] VPS RAM and CPU are unknown. The plan needs about 1.5 GB free alongside the existing app.
- Zero spend (C1). Everything below runs on free tiers, open source or testnets.
- No code until you approve this plan and hand over the new repository.

2. Three horizons

	Hackathon MVP (24 h)	Zero-cost pilot	Institutional
Data	Synthetic only, with injected anomalies and ground truth	Synthetic, plus officially published **aggregate** statistics after a legal check	Authorised data feeds under agreement
Engine	Deterministic rules R01–R12, FDR statistics, templates in 3 languages	Benchmarked ML only if it beats the rules; more rules from user feedback	Independent methodology audit
Integrity	Hoodi registry + OpenTimestamps, browser verifier, tamper demo	Reconciliation alerts, re-anchoring runbook	Mainnet or L2 anchoring with a multisig (**needs a budget**)
Accounts	Staff with MFA; citizen accounts optional (P1)	Citizen accounts, alerts, account deletion	Official SSO for officials, if ever offered
Booths	Synthetic booths, QR pages	Booth data from published official lists, with provenance	Official booth API, only with authorisation
Governance	Two-person publish, audit log	Second admin, auditor console, incident process	MoU with an election authority or recognised observer body
Ops	Live on the subdomain, nightly encrypted backups	Restore drills, uptime monitoring, an independent security test	SLA hosting, KMS or HSM keys, DPDP compliance programme

3. Hackathon MVP stages (dependency-ordered)



S2, S3 and S4 can run in parallel once S1 is done, if you have teammates.

Stage	Builds	Exit criteria
S0 Foundations	Monorepo skeleton (pnpm workspaces + Python project), local Supabase CLI, shared JSON Schemas, lint and format, CI skeleton, `.env.example`, licence and README	CI green on an empty test suite. `supabase start` works locally.

Stage	Builds	Exit criteria
S1 Synthetic data + canonicaliser	Generator (state → district → AC → parts of ≤ 1,200 electors, Devanagari and Latin names, multiple versions, deletion reasons, injected anomalies with a ground-truth file, seeded). `elcanon-1` and the Merkle tree in **Python and TypeScript**. Shared test vectors.	**AC-7**. The same seed gives byte-identical datasets.
S2 Audit engine	Diff, rules R01–R06, R08, R10 (P0) and R07, R09, R11, R12 (P1), beta-binomial + FDR, findings schema, templates in en/hi/third language, report builder, benchmark job, worker loop with leases	**AC-2, AC-8, AC-9, AC-10**
S3 Database + RLS	Migrations for all tables in Architecture §11, enums, constraints, indexes, RLS, `security definer` workflow functions, append-only audit log, fictional seed, pgTAP tests	**AC-4, AC-5**
S4 Contract + anchor + OTS	`ElectraLensRegistry.sol` with Hardhat tests, Hoodi deployment script, anchor service (ethers v6, nonce handling, receipts), OpenTimestamps stamping and upgrading in the worker, reconciliation job	Contract tests pass (no overwrite, no duplicate, fork protection, role revocation). One demo manifest anchored on Hoodi and stamped with OTS.
S5 API	Fastify, auth middleware (JWT, `aal2`, roles), public, citizen and staff routes, Turnstile verification, rate limits, problem+json errors, audit logging, signed uploads, QR SVG, claim evaluation	Route × role authorisation tests. PII scan (**AC-3**).
S6 Public web	Dashboard, comparison, finding list and detail, methodology with benchmark, browser verifier + tamper demo, booth pages + QR, claim checker (structured), guided assistant, three languages, accessibility pass	**AC-1, AC-6, AC-11, AC-12**
S7 Ops console	Staff sign-in with TOTP, steward upload and approve, analyst run, reviewer review, publisher approve, retract, job status	The full DF1 → DF3 flow done through the UI by two different staff users
S8 Deploy	Compose with hardening, nginx server block, TLS, Cloudflare and Turnstile (per D3), Docker secrets, backup cron + one restore drill, uptime monitor, alerts	Live on the subdomain. The other app unaffected. Restore drill timed and documented.
S9 Demo and pitch	Live demo script, 5-minute talk outline, judge Q&A, 45–90 s video script, adoption slide (Deliverable I)	At least one full rehearsal on the live deployment

24-hour schedule

Hours are counted from the start of the hackathon. Blocks overlap where work can run in parallel. The plan holds two fixed checkpoints: at **hour 12** the full flow must work locally end to end, even if it looks rough; at **hour 20** feature work stops.

Hours	Work	Checkpoint
0–1	S0: repo skeleton, Supabase project and keys, local Supabase, CI	CI green
1–4	S1: generator with ground truth, canonicaliser in Python and TypeScript, test vectors	**AC-7**
3–8	S2 engine (P0 rules, statistics, templates) · S3 database and RLS · S4 contract on Hoodi (in parallel)	AC-2, AC-4, AC-5, contract tests
7–11	S5 API: public and staff routes, auth middleware, Turnstile, anchor service	Route × role tests
11–12	**Checkpoint:** generate → audit → review → publish → anchor → verify, locally	Full flow works
12–17	S6 public web: dashboard, comparison, findings, methodology, verifier, tamper demo, booth + QR, claim checker, three languages	AC-1, AC-6, AC-11, AC-12
14–18	S7 ops console (minimal screens for steward, analyst, reviewer, publisher)	DF1 → DF3 through the UI
17–20	S8 deploy: compose, nginx, TLS, Turnstile, secrets, backup cron, uptime check	Live on the subdomain
20	**Feature freeze.** Only fixes from here.	—
20–22	Full test pass on the live site, seed the demo data, rehearse	AC-1 on production

Hours	Work	Checkpoint
22–24	Video, pitch and judge Q&A (S9), buffer for surprises	Submission

If the hour-12 checkpoint slips, apply the cut list below immediately rather than hoping to catch up.

Mapping to your milestones and deliverables

Your milestone	Stages	Deliverables
M1 Working audit engine	S1, S2	E
M2 Public dashboard	**S6**	G
M3 Blockchain anchoring	S1 (canon), S4, S6 (verifier)	F
M4 Database and authentication	S3, S5 (auth middleware)	C, D
M5 QR and booth information	S1 (synthetic booths), S6	G
M6 Administration and review	S3 (workflow functions), S7	D, G
M7 Production deployment	**S8**	H
M8 Independent testing	Pilot phase (test plan in the threat model §4); automated parts start in S0	—
—	**S9**	I

Deliverables A (PRD) and B (system design and threat model) are this set of documents.

Cut list (cut in this order if time runs short)

1. LLM free-text claim parsing and LLM Q&A (FR-CLM-2, FR-AST-4)
2. Voice input and output (FR-AST-3)
3. Citizen accounts, saved items, alerts (M9 citizen parts)
4. OpenTimestamps (FR-INT-4)
5. Rules R07, R09, R11, R12
6. Auditor and sysadmin screens (use SQL during the hackathon)
7. Printable QR posters (FR-QR-3)
8. Job dashboard (FR-GOV-5)

Never cut: the generator with ground truth, canonicaliser parity, deterministic rules with explanations and alternatives, the browser verifier and tamper demo, the two-person publish rule, neutrality guards, the PII scan. Together they are the product's credibility.

4. Zero-cost pilot (after the hackathon)

- Dedicated worker database role; restricted-evidence viewer with short-lived signed URLs.
- Citizen accounts, alerts, self-service deletion; privacy page and DPDP-style notice.
- Disclosure differencing checks automated in the publication pipeline.
- Second system admin (removes the single-admin gap, T02).
- Accessibility audit (WCAG 2.2 AA) and fluent-speaker review of all three languages.
- Independent security test (OWASP ZAP baseline + manual review by someone outside the team).
- Off-VPS backup automation and monthly restore drills.
- Officially published **aggregate** statistics as a real data source, only after a legal check (D9).
- Usability sessions with journalism students or civil-society volunteers. No traction is claimed until measured.

5. Needs official cooperation, legal review or money (P3)

- Authorised data access and any integration with ECI or CEO systems (needs a formal agreement).
- Official booth-information feed.
- Mainnet or L2 anchoring with a Safe multisig (gas costs money).
- A formal DPDP compliance programme and data protection officer if processing real personal data at scale.
- Independent methodology and security audits.
- Managed key storage (KMS or HSM), redundant hosting with an SLA.

6. What comes after your approval

1. You create the new repository and share it. I connect to that repository only.
2. **S0 + S1** in one stage: skeleton, generator, canonicalisers, test vectors. This fixes the names and schemas every later stage depends on.
3. Then S2 / S3 / S4 (Deliverables E, C, F), S5 (D), S6–S7 (G), S8 (H), S9 (I). I'll stop for review after each stage.

7. Decisions needed from you

ID	Decision	My recommendation
D1	Approve the scope and exclusions (PRD §8): no real data, no per-voter QR codes, no EPIC login, no party or vote data, no scraping of ECI portals	**Approve.** Each exclusion removes a legal or neutrality risk the judges would probe.
D2	Subdomain name, and which domain	`electralens.<your domain>`. Tell me the exact domain.
D3	Is that domain's DNS already on Cloudflare? Free plans can only proxy if the **whole domain's** nameservers move to Cloudflare.	If it's already on Cloudflare: proxy the subdomain. If not: moving is free but touches your other app and email records, so either move carefully (copy every record first) or skip the proxy for the hackathon and use Turnstile + nginx rate limits.
D4	Third language	Whichever language a teammate reads fluently, because every civic string needs human review. Options include Punjabi (Haryana's second official language), Bengali, Tamil or Marathi.
D5	Blockchain network	**Hoodi** (you already hold test ETH) **+ OpenTimestamps**. Use a new dedicated publisher wallet, funded from your testnet wallet.
D6	LLM use	Templates by default. Enable a free-tier LLM only behind a flag, for free-text claim parsing in the demo, and only with public evidence. Or skip the LLM entirely, since the AI value is in detection, statistics and explanation.
D7	Off-VPS backup destination	During the hackathon, a weekly encrypted dump pulled to your laptop (no new accounts). Revisit for the pilot.
D8	Stack refinements: separate Fastify API, Postgres job queue instead of Redis, Hardhat, monorepo layout	**Approve** (reasons in Architecture §2 and §16).
D9	Real data, ever	None until a legal review. The pilot uses only official aggregate statistics.
D10	Facts I need	Hackathon start time and submission deadline; **whether code, accounts or infrastructure may be prepared before the clock starts**; team members and who builds what; the organisers' official judging criteria (I won't invent any); VPS RAM and CPU; whether the site must be live before judging.

APPENDIX

Appendix — Sources and open checks

Verified facts and sources

Checked on 2026-10-27. "Secondary" means news or third-party summaries rather than the primary official document. Check those against the official source before quoting them in the pitch.

Fact	Source
SIR phases: Bihar 2025, phase II from Nov 2025, phase III announced May 2026; Delhi draft roll 5 Aug 2026, final roll 7 Oct 2026	CEO Delhi schedule, Drishti IAS, Deccan Herald (secondary)
SIR appeals go to the District Magistrate, then the CEO	West Bengal CEO press note
Four qualifying dates (1 Jan, 1 Apr, 1 Jul, 1 Oct), effective 1 Aug 2022	CEO Delhi press release, PRS
Cap of 1,200 electors per polling station (2025)	DT Next, Goa DIP (secondary)
ECINET launched Jan 2026, merging 40+ ECI apps	IANS, Daily Pioneer (secondary)
DPDP Rules notified Nov 2025, phased over ~18 months	The Week / PTI, Hogan Lovells (secondary)
Supabase Free: 500 MB DB, 1 GB storage, 50k MAU, paused after 1 week inactive, no automatic backups; basic MFA included	Supabase pricing
Custom Access Token hook available on Free	Supabase auth hooks
RBAC via custom claims; MFA `aal2` claim	Supabase RBAC, Supabase MFA
Default Supabase SMTP: 2 messages/hour, team members only	Supabase SMTP
Cloudflare Free: one rate-limiting rule, free managed ruleset only	Cloudflare WAF
Cloudflare partial (subdomain-only) setup needs Business or Enterprise	Cloudflare partial setup
Turnstile Free: unlimited challenges, 20 widgets	Turnstile plans
Sepolia recommended for app development, Hoodi for validators, Holesky deprecated Sep 2025	ethereum.org networks
OpenTimestamps calendars are free and need no API key	opentimestamps.org, opentimestamps-client
Gemini API free tier: limits changed in 2026; free-tier content may be used to improve Google products	agentdeals.dev, CostBench (secondary; check Google's terms)

Still unverified (check before relying on them)

- Whether background database queries keep a Supabase free project from pausing.
- Your VPS's RAM and CPU, and whether your domain's DNS is on Cloudflare.
- Supabase Postgres major version (for `pg_dump` client matching).
- The final text of the 2025 ECI order on the 1,200-elector cap.
- How browser speech recognition handles audio for Hindi and the third language (it may use a cloud service, depending on the browser).
- The current free-tier terms of any LLM provider we might use.
- The organisers' official judging criteria.